

How Often Is a Swallowed Failure a Bug?

A Tri-Source Study of Except-Handler Failure-Routing in AI/ML Codebases

Yufei Yang Chen*

Sun Yat-sen University, Guangzhou, China
fei76161@gmail.com

Abstract

Exception handlers that convert a failure into a success-shaped value — an LLM judge outage becoming a legitimate 0.0 score, a decode error becoming an empty string — produce wrong answers with no crash and no log line. We call this pattern *failure-routing*. This paper studies its *except-handler subfamily*: the shapes a syntactic tool can see.

We build a six-rule AST detector for this subfamily and apply it to eight pinned AI/ML packages (2,354 files, 563,270 lines). It reports 621 findings, of which 371 (59.7%) are not co-located with any finding from the union of four syntactic linters (union coverage $250/621 = 40.3\%$); for the `contextlib.suppress` shape the four shipped linters cover 0 of 19.

We then do what tool papers usually skip: we label a stratified random sample of the findings ($n = 80$). Both labelling rounds were performed by LLM agents, not humans, and agreed on all 80 items — which we report as a shared bias, not as quality. Only 12 (15.0%, Wilson95 8.8–24.4) are genuine defects; 64 (80.0%) are deliberate design contracts; 4 (5.0%) were false positives from a detector bug that the labelling itself exposed. All 12 defects occur in one package.

The paper’s central question is methodological: how do you validate a defect detector for defects whose defining property is that nobody notices them? Standard validation — “maintainers fixed it, so it was real” — fails structurally for this family. We triangulate three truth sources that ask orthogonal questions: LLM consequence labelling (15% defect), maintainer spontaneous behaviour ($13/478 = 2.7\%$ of tracked family sites ever fixed), and maintainer reaction when told ($16/43 = 37.2\%$ of the author’s family fix PRs accepted). The three are directionally consistent with the “nobody noticed” reading, but the comparison cannot support a verdict: the arms count incommensurable populations, the interval disjointness flips within the unmeasured defect composition of the tracked sites, and no matched-population substitute exists. We report this as a quantified impossibility result and name the datum that would close it.

Finally, a recall audit against 14 in-scope ground-truth defects finds 3 of 14 detected, and shows that 9 of 14 (64.3%) route the failure outside any handler — the named phenomenon is larger than the operationalised subfamily. We scope our claims accordingly and argue detectors of this kind are *search-space reducers*, not oracles.

1 Introduction

Most software failures announce themselves. An exception propagates, a process exits, a stack trace reaches a log. The failures this paper studies do none of this. A handler catches a timeout from a model API and returns 0.0, and the caller cannot distinguish that from a model that genuinely scored zero. A decode error is caught and an empty string returned, and the code downstream sees a document with no content rather than one that failed to load. Execution continues, the caller receives a value of the expected type, and a wrong answer proceeds in the shape of a right one. We call this *failure-routing*: the handler does not merely swallow the failure, it routes it into the success path. This paper studies the subfamily a syntactic tool can see — failures routed inside an `except` handler.

***Disclosure.** The author of this paper is also the author of `failroute`, the detector evaluated here, and of the `semgrep` rule reported in Section 4.2. Results unfavourable to the detector are reported alongside the favourable ones; see in particular the recall audit in Section 4.4.

The consequence is that the usual evidence of a defect is missing by construction. A crash produces a bug report; a plausible wrong number rarely produces one. Nobody files the issue, nobody writes the regression test, and the standard warrant for a static-analysis finding — that a maintainer read it and fixed it — is least available exactly where the pattern is most dangerous. Detecting these handlers is the easy half of the problem. Establishing that what we detected are defects is the hard half, and it is the half we do not fully solve.

This work began with a narrower observation. A widely used Python linter recommends a refactoring that moves the pattern out of the view of every linter we tested, including the one that recommends it.

The SIM105 observation.

- `ruff`’s SIM105 rule recommends rewriting `try/except/pass` into `contextlib.suppress(...)`. The two forms are semantically identical.
- After the rewrite, no shipped Python linter reports the construct. In our corpus, all 19 `contextlib.suppress` findings are invisible to the union of `ruff`, `bandit`, `pylint` and `flake8+bugbear` (Section 4.2). A `semgrep` rule *we wrote* covers 18 of the 19; citing it requires stating the rule is ours.
- A widely adopted refactoring therefore moves an entire defect shape out of the tools’ field of view while leaving its runtime consequences unchanged.

Contributions.

1. A taxonomy of six failure-routing shapes and an AST detector for them (Section 2).
2. A reproducible prevalence and cross-tool coverage measurement over 8 pinned packages (Section 4.2).
3. A labelled stratified sample ($n = 80$) giving a precision estimate for this detector family on real code (Section 4.3) — a negative result, whose labelling was done by LLM agents, which we disclose and analyse.
4. A tri-source triangulation for defect families where standard validation fails structurally (Section 4.5) — and a quantified impossibility result: its arms count incommensurable populations, the headline interval comparison flips within an unmeasured composition, and no matched-population substitute exists; we specify the datum that would settle the question.
5. A recall audit against maintainer-merged fixes (Section 4.4) that doubles as a construct-validity measurement: 64.3% of ground-truth defects do not route through an except-handler at all.
6. Evidence that systematic labelling is itself a detector-improvement method: it exposed a defect that accounted for 100% of one rule’s real-world findings (Section 4.6).

2 The pattern family

Six shapes, all reducible to “*a failure became a value the caller cannot distinguish from success*”:

Rule	Shape	Consequence
no-action	<code>except ...: pass</code>	caller never learns the operation failed
silent-fallback	handler returns/assigns a constant without re-raising	judge outage becomes a legitimate <code>0.0</code>
masked-exception	catch-all conditionally re-raises <i>and</i> falls back to a constant	outcome depends on which branch ran
silent-suppress	<code>with contextlib.suppress(...)</code>	same semantics as <code>except+discard</code> ; invisible to the linters we tested
implicit-fallback	handler neither re-raises, returns, nor records — falls through to implicit <code>None</code>	“did nothing” becomes a legitimate <code>None</code>
name-shadowing	<code>except E as e:</code> rebinds <code>e</code> inside the handler	Python deletes the binding on exit → <code>NameError</code> ; original exception lost

Table 1: The six failure-routing shapes.

3 Detector

The tool is the instrument, not the subject, so we describe it only to the extent needed to interpret the study. AST-based; six rules behind a shared registry; text/JSON/SARIF output; `# failroute: ignore` opt-out; `[tool.failroute]` per-rule configuration. Version 0.8.0. Quality gates: 158 tests across 3 OS $\times$ 5 Python versions, `mypy -strict`, and a hand-labelled unit corpus (v6, 68 samples: 36 positive / 32 negative) whose labels were written independently of tool output, held to precision = recall = 1.0 in CI.

Construct-validity caveat, stated up front. That 1.0 is evidence the detector matches its own specification, **not** evidence it finds real defects. Section 4.3 is the external-validity measurement, and Section 4.4 bounds how much of the phenomenon the handler-shaped operationalisation can reach at all.

4 Study

4.1 Corpus

Eight AI/ML packages fetched as pinned PyPI source distributions (not git clones), each recorded with URL, SHA-256, upload time and extracted tree hash in `paper/corpus-lock.json`.

Package	Version	Scan root	.py files	Lines
inspect_ai	0.3.260	src/inspect_ai	755	198,351
pydantic_ai_slim	2.36.0	.	298	119,534
deepteam	1.0.9	deepteam	588	71,305
trl	1.12.0	trl	155	65,727
garak	0.16.0	garak	201	38,328
smolagents	1.26.0	src/smolagents	20	13,355
uqlm	0.6.5	uqlm	91	12,605
fickling	0.1.12	fickling	16	5,024
Total (scanned)			2,124	524,229

Table 2: Pinned corpus. Per-package counts are the files *inside each scan root* — the subtree the detector actually scans — so the column sums to the total shown (2,124 .py files / 524,229 lines). The eight pinned sdist contain **2,354** .py files / **563,270** lines in total; the difference is content outside the scan roots (tests, examples, vendored code). Reproducible by anyone with network access and no git history: re-running `tools/fetch_corpus.py` yields byte-identical inputs (per-package version and SHA-256 are pinned in `paper/corpus-manifest.json` and verified against `paper/corpus-lock.json`).

4.2 RQ1 — Prevalence and cross-tool coverage

`failroute` (v0.8.0) reports **621** findings. Baselines were run on the *same* pinned trees.

Tool	Version	Rules	Findings	Co-located ± 1 line
failroute	0.8.0	all six	621	—
ruff	0.16.0	S110, S112	76	72
bandit	1.9.4	B110, B112	67	63
pylint	4.0.8	W0702/3/5/6	529	245
flake8+bugbear	7.3.0 / 25.11.29	E722, B001, B017	268	124
semgrep (our rules)	1.175.0	hand-written, 6 shapes	—	+19

Table 3: Cross-tool comparison on the pinned corpus. The `semgrep` row is *not* a shipped-rule baseline: its rule set (`tools/semgrep-rules/exception-handling.yaml`) was written by us, so it shows what a syntactic-pattern engine *can* express given rules, not what users get by default. +19 is the number of fail-route findings newly co-located once `semgrep` is added to the union (mostly the `contextlib.suppress` shape: 18 of 19).

Union of the four syntactic linters covers 250 of 621 (40.3%, 95% Wilson interval 36.5–44.2). **failroute-only**: 371 (59.7%). Adding our **semgrep** rules raises the union to 269 (43.3%, 39.5–47.2) and lowers the **failroute-only** count to 352 (56.7%).

Rule	Total	Covered by 4	Covered by 5	failroute-only (vs 4)
silent-fallback	386	175	176	211
no-action	213	72	72	141
silent-suppress	19	0 (0.0%)	18 (94.7%)	19
masked-exception	3	3 (100.0%)	3	0
implicit-fallback	0	—	—	—
name-shadowing	0	—	—	—

Table 4: Coverage by rule; “Covered by 4” is the four shipped linters, “Covered by 5” adds our self-written **semgrep** rule. **implicit-fallback** and **name-shadowing** fire zero times on this corpus; they remain in the tool because the unit corpus exercises them. On **silent-suppress**: no shipped linter reports any of the 19 findings; only a rule we wrote reaches them (18/19).

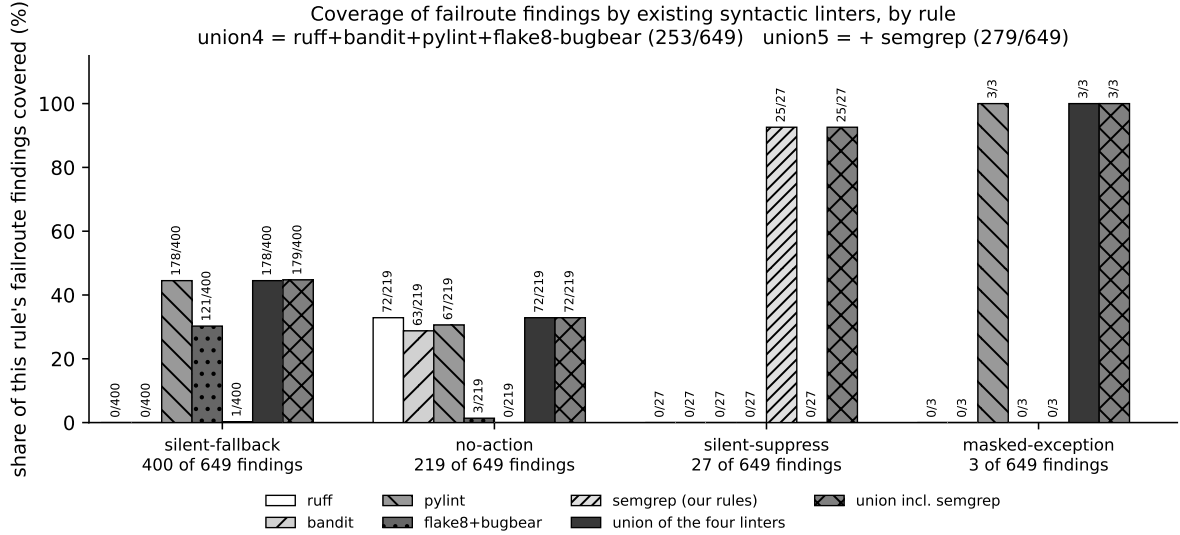


Figure 1: Per-rule coverage by tool, including the four-linter union and the five-tool union. The **silent-suppress** column is the paper’s cleanest coverage claim.

Two observations that cut against the tool.

1. **pylint** is a far stronger baseline than **ruff**. Comparing only against **ruff**’s S110/S112 — as our own earlier benchmark did — overstates novelty by roughly $3.4\times$ (72 vs 245 co-located findings). Any paper in this space that benchmarks against **ruff** alone should be read with that in mind.
2. **masked-exception** is fully covered. All 3 findings co-locate with a **pylint** broad-except warning. That rule contributes no coverage novelty here, and with $n = 3$ the 100% estimate is statistically meaningless (interval 43.9–100.0).

Methodological caveat on “coverage”. Co-location at ± 1 line means a syntactic tool *flags the same handler*, **not** that it expresses the same property. **pylint** W0703 fires on **except Exception**: regardless of what the handler does; it does not distinguish “re-raises” from “returns 0.0”. 40.3% is therefore an *upper bound* on what the syntactic tools actually say, and the semantic novelty is correspondingly higher than 59.7%. We report the conservative number.

4.3 RQ2 — What fraction are real defects?

Method. Stratified random sample over (rule $\times$ package), fixed seed (20260831), every stratum guaranteed ≥ 1 draw, remainder allocated proportionally. $n = 80$. The draw is byte-reproducible

(`tools/draw_sample.py`, SHA-256 recorded). Each finding was labelled by reading the surrounding source in the pinned tree into one of three classes: **DEFECT** (the converted failure produces a wrong caller-visible outcome with no signal), **CONTRACT** (deliberate, and either documented, commented, or expressed in the return type), **FALSE POSITIVE** (the detector is wrong about the code).

Labelling was performed by LLM agents. Two independent rounds were run, both by LLM agents (not human raters), and they agreed on 80/80 items. We do not report this as label quality: identical agreement between two runs of the same model family is evidence of *shared bias*, not of reliability. The sample remains useful as (a) a debugging instrument (Section 4.6) and (b) the consequence arm of the triangulation in Section 4.5, where its limits are part of the design.

Sampling frame. The draw was taken from the *v0.7.0 finding set* ($n = 659$). Two subsequent corrections changed the frame: labelling itself exposed the **implicit-fallback** bug whose 10 findings were all false ($659 \rightarrow 649$), and the v0.8.0 precision fixes removed 28 more ($649 \rightarrow 621$, Section 4.6). Of the 80 sampled coordinates, 72 survive in the 621 set. Of the 8 deleted items, 4 — the **implicit-fallback** findings — were labelled FALSE POSITIVE and 4 — those removed by the precision fixes — were labelled CONTRACT; *zero labelled DEFECT was lost*. The label proportions below therefore hold *within the v0.7.0 frame*, and the surviving sample is not random with respect to the 621 frame.

Label	n	Share	95% Wilson interval
CONTRACT	64	80.0%	70.0–87.3
DEFECT	12	15.0%	8.8–24.4
FALSE POSITIVE	4	5.0%	2.0–12.2

Table 5: RQ2 headline: the precision of this detector family on mature code is 15.0%, with a lower bound of 8.8%. Restricting to the 76 samples that survive as findings: $12/76 = 15.8\%$, $64/76 = 84.2\%$, false positives 0 — the labelling pass closed the loop on the one detector bug it found.

Rule	n	DEFECT	CONTRACT	FALSE POS.
silent-fallback	49	12	37	0
no-action	23	0	23	0
implicit-fallback	4	0	0	4
silent-suppress	3	0	3	0
masked-exception	1	0	1	0

Table 6: Labelling by rule. All 12 defects come from **silent-fallback** (24.5% of that rule’s sample, interval 14.6–38.1); all 4 false positives come from **implicit-fallback**.

Package	n	DEFECT	CONTRACT	FALSE POS. / defect bound
deepteam	14	12	1	1 FP; defect rate 85.7% (60.1–96.0)
inspect_ai	41	0	40	1 FP; upper 7.0%
pydantic_ai_slim	11	0	10	1 FP; upper 23.8%
trl	4	0	4	0; upper 52.7%
garak	3	0	3	0; upper 63.2%
fickling	3	0	2	1 FP; upper 63.2%
smolagents	2	0	2	0; upper 77.6%
uqlm	2	0	2	0; upper 77.6%
<i>all but deepteam</i>	66	0		upper 4.4%

Table 7: Labelling by package — the result that matters. The “upper” column is the one-sided 95% upper bound on the defect rate for zero-defect cells; small- n cells are wide and must not be read as strong evidence.

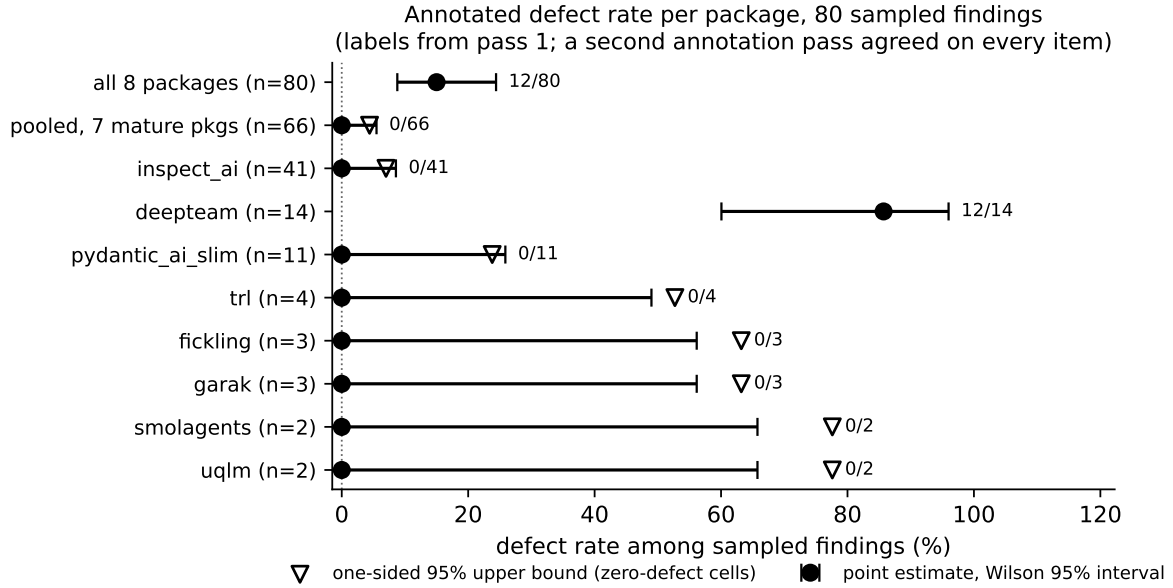


Figure 2: Measured defect rate per package with Wilson 95% intervals. Zero-defect cells are drawn as one-sided 95% upper bounds (triangles). The visual point is the spread, not the ordering.

Result (v0.7.0 frame, LLM-labelled). All 12 defects are in **deepteam**. Across the other seven packages, 0 of 66 sampled findings were defects (pooled one-sided 95% upper bound 4.4%).

The 12 defects are not 12 independent bugs. They are **three homogeneous families** replicated across metric classes:

1. **Silent criteria degradation (4/12).** try:

```
self.system_prompt = model.get_system_prompt()
except:
```

```
self.system_prompt = "". A custom or misconfigured LLM that lacks the method silently scores every subsequent case under empty criteria. (This family was independently reported upstream by the present author before this study, as deepteam#270; that report is partial external validation of the label, not of the tool.)
```

2. **Dead comparison (5/12).** try: self.score == 1 except: self.success = False. The guarded statement is a pure comparison expression that cannot raise, so the handler is dead code — and self.success is never assigned on the success path.

3. **Fail-open security verdict (3/12).** is_vulnerable() iterates results inside a try; on any error it returns vulnerable = False. In a red-teaming tool, “not vulnerable” is the most dangerous possible default: an infrastructure failure is converted into a clean security conclusion.

Conversely, the 64 contracts are overwhelmingly *deliberate and legible*: TUI widget lookups that may not be mounted, optional-dependency probes, idempotent cleanup in **finally**, and predicate functions whose **Optional/bool** return type *is* the contract. Many carry an explicit comment stating the intent (e.g. inspect_ai’s “fail open — better to skip the barrier than to hang teardown”).

Two findings in the sample are worth citing as **positive** examples of the discipline this paper argues for: pydantic-ai’s **is_private_ip** fails *closed* on an unparseable address (“Invalid IP address, treat as potentially dangerous” → **return True**), and its **_run_tool** explicitly routes a caught exception onto a queue *so that the consumer re-raises it* rather than letting it vanish.

4.4 RQ3 — Recall audit and construct validity

An unusual ground truth is available: upstream fixes in this defect family that the projects’ own maintainers reviewed and merged. Of 75 merged pull requests authored by the present author, **16** are failure-routing fixes — every exclusion adjudicated by reading the PR diff (52 earlier title-only judgments were re-checked against diffs in a dedicated pass; 49 stood, 3 flipped). For each family fix, the file was fetched at the merge commit’s *first parent* (i.e. immediately pre-fix) and scanned.

	Class	<i>n</i>	Cases
Out of scope for recall		2	one TypeScript change (language scope); one prefix crash with no family shape
Detected		3	uqlm#450, agent-sweep#197, trulens#2653
Handler-shape gap (design-reachable)		2	inspect_ai#5068 (post-handler state mutation), #4906 (tenacity RetryError masking) — both adjudicated as candidate patterns, not shipped
Non-handler routing		9	NaN reaching aggregates, silent list filtering, branch-level Score(0.0) , implicit- None contract violations, silent character stripping, silent symbol dropping, laundered verdicts

Table 8: Classification of the 16 family fixes (J-batch ledger; `paper/merged-pr-recall.csv`, all rows diff-read).

Recall on the corrected denominator: 3 of 14 = 21.4% (95% Wilson interval 7.6–47.6). The ceiling for *any* handler-shaped detector on this ground truth is 5 of 14 = 35.7%, because **9 of 14 = 64.3% (38.8–83.7) of the defects route the failure outside any except-handler.**

This is the paper’s construct-validity result, and it bounds the whole approach: the phenomenon named in the title is larger than the subfamily the tool (and every handler-shaped detector) operationalises. We state this as a boundary *and* a roadmap — dataflow-shaped failure-routing is future work — and we scope all claims in this paper to the except-handler subfamily accordingly.

Detection recall on merged fixes that belong to the failure-routing family

repo	PR	fix title (truncated)	detected	rule matched	note
uqlm	#462	fix(longform): surface NLJ retry exhaust	NO	—	miss reason: pre-fix defect is NaN produced by exhausted retries reachi...
inspect_ai	#5068	fix(view): raise a friendly error on A	NO	—	miss reason: handler converts failure via post-handler state mutation (...)
uqlm	#459	fix(panel): keep one failed judge from	NO	—	miss reason: failed judge’s NaN entered panel aggregates via data flow,...
PyRIT	#2466	FIX: reject selected attack techniques	NO	—	miss reason: unresolvable techniques were dropped by silent list filter...
PyRIT	#2460	FIX: surface auth config fetch failure	N/A	—	TypeScript (web UI): failroute is Python-only -> out of language scope
uqlm	#450	fix(generation): preserve prompt-respo	YES	no-action	matched: uqlm/utis/response_generator.py:252(no-action)
inspect_ai	#4906	Report the sandbox’s error when remote	NO	—	miss reason: failure masking lives inside tenacity retry semantics (opa...
inspect_evals	#2167	fix(swe_lancer): exclude samples with	NO	—	miss reason: broken invariant was converted to Score(value=0.0) by an o...
uqlm	#425	fix(nil): guard against ZeroDivisionEr	NO	—	miss reason: pre-fix code crashed (ZeroDivisionError propagated): the f...
uqlm	#418	fix(white_box): return NaN instead of	N/A	—	pure-additive fix: pre-fix defect is a non-handler implicit-None (funct...

Recall 1/10 = 10.0% (Wilson 95%: 1.8-40.4%) against all 10 family fixes; 1/8 = 12.5% (Wilson 95%: 2.2-47.1%) against the 8 in-scope subset (out-of-scope rows carry detected=n/a). Denominators recounted from `paper/merged-pr-recall.csv` by `tools/compute_intervals.py`.

Figure 3: Recall by defect family against the merged-fix ground truth.

Side observation. In the pre-fix `inspect_ai #5068` file the detector flagged a *different, unfixed* `silent-fallback` at line 356. Real code contains same-family defects that no one has reported.

4.5 RQ3b — A tri-source triangulation

The precision result invites the obvious rebuttal: *if 85% of findings are not defects, the detector is noise*. The equally obvious defence — *the defects are real, maintainers just have not noticed them* — is exactly what a false-positive-heavy tool would say, and on spontaneous behaviour alone it is unfalsifiable. We triangulate three truth sources that ask *orthogonal questions* — of, as it turns out, *non-commensurable populations*, which is what bounds the conclusion below.

Verdict: directionally consistent, not established. The natural headline reading is arithmetic: arm 3’s interval lower bound (24.4%) lies above arm 2’s upper bound (4.6%), the intervals are disjoint, and disjointness is read as supporting “nobody noticed” over “false positive”. The arithmetic is right and the reading is not: what the two denominators count is different, and neither count is warranted.

Arm	Measures	Value	Wilson95
1 — consequence labelling (Sec. 4.3)	“if triggered, how bad is it?”	12/80 = 15.0% defect, all in one package	8.8–24.4
2 — maintainer spontaneous behaviour	“did anyone notice without prompting?”	13/478 = 2.7% of family sites ever fixed	1.6–4.6
3 — maintainer reaction when told	“when surfaced, do they accept?”	16/43 = 37.2% of our family fix PRs merged	24.4–52.1

Table 9: The three truth sources. Arm 2 ground truth is a maintainer-behaviour dataset over the same eight pinned packages (478 family sites classified FIXED/SURVIVED from package history; none of the 13 FIXED sites traces to an author report — the 9 PR-attributed fixes match no author PR, and the 4 unattributed ones were cleared by package and content check). Arm 3 ground truth is the merged/closed record of family fix PRs authored by the present author: the 16 merged members are itemised in `paper/merged-pr-recall.csv` — 8 of them in packages outside the tracked eight — and the 27 closed-unmerged members are itemised, with per-PR closure reasons, in `paper/h1_arm3_classification.csv` (copied into this artifact set from the unreleased companion repository so the composition is third-party checkable): 19 self-closed, 1 bot-closed, 3 closed without reaching the merits, 2 substantively accepted, and 2 adverse on the merits (Section 4.5). Excluding the 19 self-closures, acceptance is $16/24 = 66.7\%$ (46.7–82.0) at PR level — one closure (`uqlm#427`) shares its defect substance with a counted merge (`#462`) and two more duplicate other submissions, so the 43 PRs overcount distinct defects.

The arms are not commensurable. Arm 2’s denominator is all 478 tracked family sites; arm 3’s is 43 defect candidates pre-screened by the author, of whose 16 merged members 8 lie in packages outside the tracked eight. A site-level rate and a self-selected-candidate rate answer different questions about different populations; no interval comparison between them can support a population-level verdict.

The disjointness depends on an unmeasured composition. Whether the intervals are disjoint depends on two quantities that were never measured: n , the number of the 478 tracked sites that are genuine defects, and $k \leq 13$, the number of the 13 spontaneous fixes that landed on defect sites. Table 10 evaluates the comparison across the plausible range. Taking all 478 sites as the risk set ($k=13, n=478$) — which counts the $\sim 85\%$ of findings our own labelling calls deliberate contracts as if they were opportunities to fix a defect — yields disjointness. But under this paper’s own 15% base rate ($n \approx 72$) with fixes concentrated on defects ($k=13$) — arguably the natural composition, since maintainers fix bugs rather than contracts — arm 2 becomes $13/72 = 18.1\%$ (10.9–28.5), which *overlaps* arm 3 on 24.4–28.5. Disjointness survives only if $n \geq 86$, i.e. only if the defect share among tracked sites is at least 18.0% — strictly above this paper’s own precision estimate. And the 15% is itself LLM-labelled (Limitation 1): if it cannot be trusted, there is equally no independent warrant for the $n=478$ denominator. Neither corner is selectable on evidence, and Limitation 2 says n cannot be measured from spontaneous behaviour at all — that is precisely the family’s defining problem.

k	n	k/n	Wilson95	Disjoint?	Composition reading
13	478	2.7%	1.6–4.6	yes	all tracked sites as risk set
13	144	9.0%	5.4–14.8	yes	30% defect share
13	86	15.1%	9.1–24.2	yes	boundary
13	85	15.3%	9.2–24.4	no	just below boundary
13	72	18.1%	10.9–28.5	no	this paper’s own 15% base rate
6	72	8.3%	3.9–17.0	yes	half the fixes were defect fixes
2	72	2.8%	0.8–9.6	yes	fixes $\propto$ defect share (13×0.15)

Table 10: The arm-2/arm-3 comparison as a function of the unmeasured defect composition: n = defect sites among the 478 tracked, k = defect-site fixes among the 13 spontaneous fixes. Arm 3 is fixed at 16/43 (24.4–52.1); “disjoint” means the arm-2 upper bound lies below 24.4. The verdict flips within the plausible range, and neither k nor n is measured — n is not measurable from spontaneous behaviour (Limitation 2).

No commensurable substitute exists. The natural repair — compare only sites that are both tracked and PR-reported — is empty: none of the 16 merged family fixes maps to any of the 478 tracked sites (zero exact file matches; the tracked population and the author-reported population are near-disjoint,

a consequence of the 3/16 recall and of the 8 out-of-corpus fixes). The closest available approximation is package-level: in `uqlm`, 0 of 12 tracked family sites were spontaneously fixed through the tracked window (0.0–24.2%) while 5 of 5 author-reported `uqlm` family fixes were merged (56.6–100.0%). Same maintainer team — but different site sets, author-selected, and n too small to exclude almost anything. We report it as context, not as a test.

What survives. Three things, each weaker than a verdict. (i) Directly: the itemised closure record (`paper/h1_arm3_classification.csv`) shows maintainer engagement with surfaced family defects was mostly, but not uniformly, favourable. Of the 24 non-self-closed outcomes (16 merged, 7 maintainer-closed, 1 bot-closed), the 16 merges and two closures accepted the substance — in `giskard-oss#2614` the maintainer landed an equivalent fix; `uqlm#427` was process-closed with its substance partially re-landed via merged `#462` — three never reached the merits (two AI-assistance-policy closures of the same *hypothesis* diff, one duplicate), and **two were adverse on the merits**: in `uqlm#452` the maintainer questioned the reachability of the failure and the question was never resolved — the closest thing in the record to a dispute of the defect’s existence — and `vllm-metal#541` was declined as speculative hardening rather than a documented gap. The direct evidence against the *strong* false-positive reading is therefore real but mixed: favourable in 18 of the 24 outcomes at PR level, adverse on the merits in 2, non-merits or non-maintainer in 4 — and all of it on an author-selected subset. (ii) Spontaneous repair of tracked family sites is rare (2.7%) whatever their composition — but by Limitation 2 that rarity is equally consistent with “mostly contracts”. (iii) The datum that would settle “nobody noticed” against “false positive” — maintainer reaction to a *random* sample of findings — does not exist and cannot be retro-constructed. We state the question as open and record that datum as a design requirement for future work.

The four limitations, stated with the result.

1. Arm 1 is LLM-judged (two rounds, same model family, 80/80 agreement = shared bias, not quality).
2. Arm 2’s SURVIVED label is only readable as “nobody acted”, never as “deliberate contract” — for this family the two are indistinguishable, which is precisely why spontaneous behaviour cannot validate the detector.
3. Arm 3’s selection bias is irreducible: acceptance applies only to the self-selected reports, not to the detector’s findings at large.
4. The arms are not commensurable: arm 2 counts tracked sites, arm 3 counts author-selected defect candidates, and 8 of the 16 merged candidates lie outside the tracked packages. No interval comparison between them yields a population-level verdict (Verdict, above; Table 10).

4.6 RQ4 — Labelling as a detector-improvement method

All four false positives in the sample were `implicit-fallback`, and all four had the *same* root cause: `_has_top_level_terminal()` inspected only *direct* statements of the handler body, so a `return/raise` nested inside an exhaustive `if/else` was invisible. Four real shapes triggered it:

Package	Function	Shape
<code>deepteam</code>	<code>simulate_baseline_attacks</code>	<code>if ignore_errors: return [...] else: raise</code>
<code>fickling</code>	<code>check_pickle</code>	<code>nested try/except</code> , every path returns
<code>inspect_ai</code>	<code>grok generate</code>	<code>if/elif/else</code> , every branch returns or raises
<code>pydantic_ai</code>	<code>execute_output_function</code>	<code>if wrap: raise ToolRetryError else: raise</code>

Table 11: The four shapes that exposed the detector bug.

We implemented a recursive exhaustiveness analysis (`_always_terminates`) covering `if/else`, `with`, `try/except/finally` and `match`, added six regression tests derived from the four real shapes (each failing before the fix), and re-ran the corpus.

implicit-fallback findings on 563k lines: 10 → 0. Total findings: 659 → 649 (v0.7.0). The v0.8.0 precision release removed 28 more findings through four audited fixes (tuple-typed handlers, `warnings.warn` recognised as a signal, `StopAsyncIteration` added to the ignore list, conservative optional-dependency probe): **649 → 621**, with every deletion traceable to a labelled category or a mechanical criterion — no labelled DEFECT was removed. Test count: 124 → 130 → **158**.

Two things follow. First, the rule’s entire real-world yield was false. Second, and this is the transferable point: **a stratified labelling pass is not only an evaluation instrument; it is the most**

efficient defect-finding method we applied to our own detector. The unit corpus (68 samples, precision = recall = 1.0) never exposed this bug, because the corpus was written by the same person, with the same blind spot, as the detector.

5 Discussion

A detector this imprecise is still useful, but not as an oracle. On our corpus a maintainer following up every finding would read 621 handlers to reach ~ 93 genuine defects — a cross-frame extrapolation (the 15.0% LLM-labelled share is measured on the v0.7.0 sample frame; the 621 count is v0.8.0), not a measurement; see the caveat in Section 6 — of which the vast majority are three copy-paste families in a single package. As an *alarm*, that is unusable. As a *search-space reducer* over 563k lines, it is a different proposition: it narrowed the space by roughly three orders of magnitude (from 563k lines to 621 findings, a factor of 907), and a reading of 80 sampled handlers found a systematic fail-open security verdict in a red-teaming tool.

The triangulation reframes the negative precision result — as an impossibility result. 15% defects is bad for an alarm and unremarkable for a search tool; the interesting fact is that the family’s defining property — silence — also disables the usual external check on the number. Spontaneous repair of tracked family sites was 2.7%; when the author surfaced adjudicated defect candidates, acceptance was 37.2%. These numbers measure different populations and cannot be combined into a verdict (Section 4.5): rebased under this paper’s own defect share, the intervals overlap. What the triangulation establishes is narrower and, we believe, more useful: for this family neither spontaneous behaviour nor triangulation around it can validate a detector; the reason is quantifiable (an unmeasured two-dimensional composition, Table 10); and the missing datum is nameable — maintainer reaction to a random sample of findings.

Yield tracks codebase maturity, not rule design. The strongest predictor of whether a finding is a defect was not *which* rule fired but *which package* it fired in. The mature, heavily-reviewed packages had essentially no defects and a large number of carefully-commented intentional contracts; the one package with a systematic problem had it replicated across dozens of near-identical files. This suggests triage effort should be allocated per-package after a cheap pilot sample, not uniformly.

The contextlib.suppress blind spot is real. 0/19 of the findings are visible to any shipped linter, and a popular lint rule actively drives code toward that shape. Only a semgrep rule we wrote reaches them (18/19).

Adoption, honestly. The tool is published on PyPI; at the measurement moment it has **1 star and 0 forks**. We claim no adoption and no impact beyond the measurements in this paper; the maintainer-behaviour dataset and the triangulation method are the contributions we ask the reader to weigh.

On “tool proposes, human adjudicates”. We report a case where we ran the detector over a well-maintained red-teaming framework, sampled twelve semantic findings, traced each, concluded all twelve were deliberate contracts, and *filed nothing*. Given the 15% base rate measured here, that outcome is what the numbers predict, not an anomaly.

6 Threats to validity

- **Limitation 1 — the labelling arm is LLM-judged.** Both labelling rounds were performed by LLM agents, not human raters; the rounds agreed on 80/80 items, which we read as *shared bias of one model family, not as inter-rater reliability*. No Cohen’s κ is possible between two runs of the same rater species. All arm-1 proportions inherit this limit.
- **Limitation 2 — SURVIVED is ambiguous in this family.** In the maintainer-behaviour dataset, SURVIVED can only be read as “nobody acted”; it can *not* be read as “maintainers consider it a deliberate contract”, because for silent defects the two are observationally identical. Any number derived from arm 2 inherits this reading restriction.

- **Limitation 3 — arm-3 selection bias is irreducible.** The author chose which defects to report as PRs; acceptance (16/43) applies only to that self-selected set and cannot be extrapolated to the detector’s findings. Reporting only merged PRs would have made this worse; the 27 closed-unmerged family PRs are counted in the denominator and are itemised, with closure reasons, in `paper/h1_arm3_classification.csv` (copied from the unreleased companion repository so the composition is checkable). Three counting caveats: one of the 8 non-self-closures was a *bot* action, not a maintainer judgement; two of the 27 duplicate other submissions and one more shares its defect substance with a counted merge, so the 43 PRs overcount distinct defects; and 8 of the 16 merged fixes lie in packages outside the tracked eight — arm 3’s population is not arm 2’s.
- **Limitation 4 — the triangulation’s arms are not commensurable.** Arm 2 counts tracked sites; arm 3 counts author-selected defect candidates. The headline interval comparison depends on an unmeasured composition (Section 4.5, Table 10) and supports no population-level verdict; we report directional consistency only.
- **Sample size.** $n = 80$ of the v0.7.0 frame (659). Per-rule and per-package cells are small (`masked-exception` $n = 1$). Wilson intervals are reported throughout instead of bare point estimates.
- **Sample frame changed under the sample.** The draw came from v0.7.0’s 659; 72/80 coordinates survive in v0.8.0’s 621, and the deletions removed zero labelled DEFECTs — but the surviving 72 are no longer a random sample of the current frame. Label proportions are stated for the v0.7.0 frame only.
- **Package selection is not random.** The eight packages were chosen because the author had prior contribution history in them. `deepteam` in particular is a package where the author had *already found* a defect family, which inflates the overall defect rate. The seven-package 0/66 figure is the more conservative read.
- **Recall ground truth is authored by the same person.** The 16 merged family fixes were written and submitted by the author; a maintainer merge records that the change was acceptable to the project — it is not a maintainer finding that the pre-fix behaviour was a defect, and it says nothing about representativeness. The family adjudication of all 75 merged PRs was done by reading diffs (52 earlier title-only judgements were re-verified from diffs in a dedicated pass, with 3 corrections).
- **Co-location $\neq$ equivalent detection** (Section 4.2 caveat). Reported conservatively as an upper bound on baseline coverage.
- **The fifth baseline tool is ours.** The `semgrep` rule counted in the five-tool union was written by the authors; coverage attributed to it is self-supplied.
- **Construct validity (Section 4.4).** The detector operationalises the except-handler subfamily only; 64.3% of ground-truth defects lie outside it. All prevalence/recall claims are scoped to the subfamily.
- **Version pinning is a snapshot.** All findings are relative to the pinned versions in `paper/corpus-lock.json`; upstream may have fixed or introduced instances since.

7 Related work

Failure handling as an empirical object. Exception handling has a long empirical literature in statically typed languages: Cabral and Marques’ field study of Java and .NET [5] documented how often exceptions are caught and swallowed; Sawadpong et al. [20] characterised exception-handling *defects*; and de Pádua and Shang quantified the prevalence of named exception-handling anti-patterns over a large corpus [3] and revisited developer practice through exception-flow analysis [7]. That line of work asks *whether* anti-patterns occur and *how often*. Our closest neighbour is it: we inherit the premise that handling shape is measurable, and change the question. On a corpus of Python AI/ML packages, the same syntactic shapes that read as anti-patterns are predominantly *intended contracts* — in our stratified sample of 80 sites, 80.0% carried a contract reading and 5.0% were outright false positives, with the defect share concentrated almost entirely in one package. Reporting a prevalence number without that breakdown is what makes the earlier literature unreadable as a triage instruction.

Why generic rules get muted. A second body of work explains the reception of such numbers. Developers report false positives and noise as the leading reason they ignore or abandon static analysis [12]; Ruthruff et al. made *actionability* an experimental target rather than a slogan [16]; Google’s Tricorder and FindBugs-Fixit programmes showed that an analysis only survives at scale when it is filtered, prioritised and paired with a suppression path [18, 2, 17]. User-centred and follow-up studies reach the

same ordering from the other side: what developers need is a warning they can act on [9, 22], and the mitigation of false positives remains an open problem rather than a solved one [10]. WarningsGuru operationalised relevance with statistical bug models [15], and Hu et al. recently measured the other end of the same pipe — which warnings developers actually suppress, and on what grounds [11]. Crisan and McNutt frame linting as a sociotechnical activity [6]. Our contribution is not another relevance filter: it is a *semantic* account of why a particular family of syntactic matches is disproportionately non-actionable, so that a suppression decision can be justified by code shape rather than by developer fatigue.

Silent failure in machine-learning systems. The systems literature supplies the stakes. Sculley et al. named the pipeline coupling and glue-code debt that makes ML behaviour brittle [21]; Breck et al. proposed continuous data validation as the corrective at the data boundary [14]; the ML Test Score encoded a rubric that tests the pipeline rather than the model alone [4]; Amershi et al. and Paleyes et al. documented that the failures arrive at integration and deployment time, not training time [1, 13]; Sambasivan et al. traced how a data problem cascades through a high-stakes system until it surfaces as an unexplained outcome [19]; and Dixit et al. measured silent corruption at the hardware layer where no exception is raised at all [8]. Zhang et al. position testing and robustness techniques across that same spectrum [23].

Increment over the two closest studies. Read side by side, de Pádua and Shang [3] and Hu et al. [11] bound the problem on either side: the first measures how often a handling shape appears, the second measures what developers do once a tool points at it. Neither asks, *per site*, whether the flagged construct is a defect, an intended contract, or a tool artefact — and neither reports what a purely syntactic linter fails to see at all. This paper supplies both measurements for Python AI/ML code: a labelled 80-site sample (12 DEFECT / 64 CONTRACT / 4 FALSE POSITIVE, with the defect mass concentrated in one package), and a cross-tool comparison showing that four widely used syntactic linters jointly cover 40.3% of the 621 routed-failure sites we detect, with one entire pattern — `contextlib.suppress`-style silent suppression — at 0/19 to shipped rules. The increment is therefore empirical and narrow: the *meaning* of a flagged handler, and the *coverage boundary* of the tools practitioners actually run.

8 Conclusion

Except-handler failure-routing is a real and prevalent shape in AI/ML Python: 621 instances in 563k lines, 59.7% of them outside the reach of four mainstream syntactic linters and 100% of the `contextlib.suppress` variant outside the reach of all shipped linters. But prevalence is not defectiveness. In an LLM-labelled stratified sample, 15% were genuine defects and 80% were deliberate contracts, with the defects concentrated entirely in a single package.

The methodological contribution is a quantified impossibility result. For a defect family whose defining property is silence, “did maintainers fix it?” is a broken validation instrument — spontaneous repair of tracked family sites was 2.7% — and the natural workaround fails too: triangulating against maintainer reaction when told (37.2% acceptance of author-reported candidates) compares incommensurable populations, and the interval disjointness that appears to support the “nobody noticed” reading flips to overlap under this paper’s own defect share, with no matched-population substitute and no independent warrant for either denominator. What remains is honest but narrower: directionally consistent observations, a closure record in which maintainer adjudication of surfaced family defects was favourable in 18 of 24 outcomes but adverse on the merits in two (an unresolved reachability challenge and a scope decline), and an open question whose missing datum we name — maintainer reaction to a random sample of findings. And the recall audit supplies the honest boundary: 3 of 14 ground-truth defects detected, and 64.3% of them route the failure outside any handler — the phenomenon is larger than the subfamily we, and every handler-shaped detector, can see.

We think the useful conclusion is not “this class is undetectable” but that detectors for it should be designed, evaluated and *deployed* as search-space reducers with an explicit human adjudication step — and that the labelling pass which establishes that should be run early, because in our case it was also the fastest way to find a bug in the detector itself.

Reproduction

Every number in this paper is produced by the scripts in `tools/` against the pinned corpus in `paper/corpus-lock.json`.

```
cd <repo-root>
pip install '[test,paper]' # pytest + matplotlib + the five linters
.venv/bin/python tools/fetch_corpus.py # pinned sdists -> paper/corpus/
# version+sha256 pinned in paper/corpus-manifest.json; fetch verifies each
# archive against paper/corpus-lock.json and exits non-zero on mismatch
PYTHONPATH=src .venv/bin/python tools/rescan_corpus.py --out bench/rescan-v0.8
# rescan with the current detector (total 621). Writes to bench/; do NOT
# re-export over paper/scan/, which is the frozen v0.7.0 baseline
.venv/bin/python tools/coverage_union.py --findings-dir bench/rescan-f2
# -> bench/corpus-coverage-union.json ; union 250/621 = 40.3%
# (the default --findings-dir paper/scan is the frozen v0.7.0 finding set;
# its union figure is deprecated -- use bench/rescan-f2 for the number above)
.venv/bin/python tools/j1_adjudicate.py # J1 diff-read adjudication
.venv/bin/python tools/compute_intervals.py # -> paper/intervals.json
.venv/bin/python -m pytest # 158 tests
```

Three further pipeline commands are deliberately *not* part of the reproduction path, because each overwrites a hand-curated artifact without regenerating it faithfully: `draw_sample.py` (the committed `paper/sample.jsonl` was drawn from the pre-fix 659 frame; re-drawing changes which 80 findings the published labels describe), `merged_pr_recall.py` (drops the hand-written `note` column), and `compare_linters_corpus.py` (drops the merged semgrep results). See `paper/ARTIFACT.md` §0.2 and §5.5–5.6 before running any of them.

Key artifacts, and the thing each one pins down:

- `paper/corpus-lock.json` — pinned inputs.
- `paper/sample.jsonl` — the 80-item draw.
- `paper/annotations.csv` — labels and rationale.
- `paper/annotations-second-pass.csv` — second automated pass.
- `paper/merged-pr-recall.csv` — recall ground truth (all rows diff-read).
- `paper/j1-trulens2653-prefix.py` — pre-fix evidence for the `trulens#2653` detection.
- `bench/corpus-coverage-union-5tool.json` — cross-tool coverage including the self-written semgrep rule.
- `paper/intervals.json` — Wilson intervals.
- `paper/h1_arm3_classification.csv` — the arm-3 closed-PR ledger (160 diff-read rows; 27 family), copied byte-identically from the companion repository.

Two things a reproducer must know.

1. If the checkout path contains non-ASCII characters, an *editable* install of this package does not work (the generated `.pth` pointer is mangled), so every CLI invocation must carry `PYTHONPATH=src`.
2. The scanner exits with status 1 whenever it finds anything, even when the run succeeded and the export was written. Under `set -e` or in CI, a successful scan looks like a failure.

References

- [1] Saleema Amershi, Andrew Begel, Christian Bird, Robert DeLine, Harald Gall, Ece Kamar, Nachiappan Nagappan, Besmira Nushi, and Thomas Zimmermann. Software engineering for machine learning: A case study. In *2019 IEEE/ACM 41st International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, pages 291–300, 2019.
- [2] Nathaniel Ayewah and William Pugh. The google findbugs fixit. In *Proceedings of the 19th international symposium on Software testing and analysis*, pages 241–252, 2010.
- [3] Guilherme Bicalho De Padua and Weiyi Shang. Studying the prevalence of exception handling anti-patterns. In *2017 IEEE/ACM 25th International Conference on Program Comprehension (ICPC)*, pages 328–331, 2017.

- [4] Eric Breck, Shanqing Cai, Eric Nielsen, Michael Salib, and D. Sculley. The ml test score: A rubric for ml production readiness and technical debt reduction. In *2017 IEEE International Conference on Big Data (Big Data)*, pages 1123–1132, 2017.
- [5] Bruno Cabral and Paulo Marques. Exception handling: A field study in java and .net. In *Lecture Notes in Computer Science*, pages 151–175, 2007.
- [6] Anamaria Crisan and Andrew M McNutt. Linting is people! exploring the potential of human computation as a sociotechnical linter of data visualizations. In *Proceedings of the Extended Abstracts of the CHI Conference on Human Factors in Computing Systems*, pages 1–10, 2025.
- [7] Guilherme B. De Padua and Weiyi Shang. Revisiting exception handling practices with exception flow analysis. In *2017 IEEE 17th International Working Conference on Source Code Analysis and Manipulation (SCAM)*, pages 11–20, 2017.
- [8] Harish Dixit. Keytone: Silent data corruptions at scale. In *2023 IEEE 29th International Symposium on On-Line Testing and Robust System Design (IOLTS)*, pages 1–2, 2023.
- [9] Lisa Nguyen Quang Do, James R. Wright, and Karim Ali. Why do software developers use static analysis tools? a user-centered study of developer needs and motivations. *IEEE Transactions on Software Engineering*, 48:835–847, 2022.
- [10] Zhaoqiang Guo, Tingting Tan, Shiran Liu, Xutong Liu, Wei Lai, Yibiao Yang, Yanhui Li, Lin Chen, Wei Dong, and Yuming Zhou. Mitigating false positive static analysis warnings: Progress, challenges, and opportunities. *IEEE Transactions on Software Engineering*, 49:5154–5188, 2023.
- [11] Huimin Hu, Yingying Wang, Julia Rubin, and Michael Pradel. An empirical study of suppressed static analysis warnings. *Proceedings of the ACM on Software Engineering*, 2:290–311, 2025.
- [12] Brittany Johnson, Yoonki Song, Emerson Murphy-Hill, and Robert Bowdidge. Why don’t software developers use static analysis tools to find bugs? In *2013 35th International Conference on Software Engineering (ICSE)*, pages 672–681, 2013.
- [13] Andrei Paleyes, Raoul-Gabriel Urma, and Neil D. Lawrence. Challenges in deploying machine learning: A survey of case studies. *ACM Computing Surveys*, 55:1–29, 2022.
- [14] Neoklis Polyzotis, Martin Zinkevich, Sudip Roy, Eric Breck, and Steven Whang. Data validation for machine learning. In *Proceedings of the Machine Learning and Systems Conference (MLSys) 2019*, 2019.
- [15] Louis-Philippe Querel and Peter C. Rigby. Warningsguru: integrating statistical bug models with static analysis to provide timely and specific bug warnings. In *Proceedings of the 2018 26th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 892–895, 2018.
- [16] Joseph R. Ruthruff, John Penix, J. David Morgenthaler, Sebastian Elbaum, and Gregg Rothermel. Predicting accurate and actionable static analysis warnings. In *Proceedings of the 30th international conference on Software engineering*, pages 341–350, 2008.
- [17] Caitlin Sadowski, Edward Aftandilian, Alex Eagle, Liam Miller-Cushon, and Ciera Jaspán. Lessons from building static analysis tools at google. *Communications of the ACM*, 61:58–66, 2018.
- [18] Caitlin Sadowski, Jeffrey Van Gogh, Ciera Jaspán, Emma Soderberg, and Collin Winter. Tricorder: Building a program analysis ecosystem. In *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, pages 598–608, 2015.
- [19] Nithya Sambasivan, Shivani Kapania, Hannah Highfill, Diana Akrong, Praveen Paritosh, and Lora M Aroyo. “everyone wants to do the model work, not the data work”: Data cascades in high-stakes ai. In *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems*, pages 1–15, 2021.
- [20] Puntitra Sawadpong, Edward B. Allen, and Byron J. Williams. Exception handling defects: An empirical study. In *2012 IEEE 14th International Symposium on High-Assurance Systems Engineering*, pages 90–97, 2012.

- [21] D. Sculley, Gary Holt, Daniel Golovin, Eugene Davydov, Todd Phillips, Dietmar Ebner, Vinay Chaudhary, Michael Young, Jean-François Crespo, and Dan Dennison. Hidden technical debt in machine learning systems. In *Advances in Neural Information Processing Systems 28 (NeurIPS 2015)*, 2015.
- [22] Rahul Yedida, Hong Jin Kang, Huy Tu, Xueqi Yang, David Lo, and Tim Menzies. How to find actionable static analysis warnings: A case study with findbugs. *IEEE Transactions on Software Engineering*, 49:2856–2872, 2023.
- [23] Jie M. Zhang, Mark Harman, Lei Ma, and Yang Liu. Machine learning testing: Survey, landscapes and horizons. *IEEE Transactions on Software Engineering*, 48:1–36, 2022.